

● CODE REVIEW

4 places a bug hides in plain sight.

Lessons from wp2shell, the WordPress core RCE. Go
grep your own repo for these.

- 1 // PARALLEL ARRAYS

Two lists kept in sync by hand.

GREP FOR

A loop that appends to array A and array B, then reads both by the same index later. One branch that updates one but not the other silently breaks the mapping.

IN wp2shell

\$matches and \$validation drifted one apart, so a request ran against another request's handler.

- 2 // GUARDED SANITIZER

Sanitizing inside an if.

GREP FOR

`absint / intval / esc_*` or an `is_array()` check wrapping a sanitizer. When the guard is false, the value flows through untouched.

IN `wp2shell`

`absint()` ran only inside `is_array()`. A string skipped it and landed raw in the SQL query.

- 3 // EARLY EXITS

continue or return before the invariant.

GREP FOR

An error or edge branch that continues or returns after doing only PART of the bookkeeping the normal path completes.

IN wp2shell

The error branch appended to \$validation, then continued, skipping the matching \$matches append.

- 4 // FAIL OPEN

The unexpected path proceeds.

GREP FOR

else and default branches that keep going instead of refusing. Ask of every edge path: does it still hold the guarantee, or just carry on without it?

IN wp2shell

Both bugs fail open. The edge path runs the operation instead of rejecting it.

- THE PATTERN

**One invariant.
One missed
branch.**

That is all it takes to ship a critical bug. Full breakdown, both CVEs, and a lab you can run:

[zenithgenius.github.io/
wordpress-batch-rce-lab](https://zenithgenius.github.io/wordpress-batch-rce-lab)